appendix C
What is CSRF?

Chapter 6 introduced the concept of cross-site request forgery (CSRF). This appendix takes a closer look at CSRF.

C.1 What is CSRF?

Let's step out of the CORS mindset for a bit and talk about regular, old same-origin requests. Cookies are always included on same-origin requests, regardless of how that request was initiated. If you're logged in to www.twitter.com, any time your browser navigates to a www.twitter.com site, the cookies will be included in the request. It doesn't matter where the request originates: you can visit www.twitter.com directly or click a link to go to www.twitter.com. Even if a page merely links to an image hosted on www.twitter.com, the request for that image will include your cookies. You have no control over this behavior. If your browser has cookies associated with a site, they're always included on the request.

Suppose a hacker creates a page that adds a new tweet to Twitter. Whenever someone visits this site, it sends a request to Twitter to create a tweet that says, "I have hacked your site!" (see figure C.1). If the hacker can somehow trick you into visiting his page, the tweet will be added to your own Twitter feed!

This is at the heart of CSRF: an unauthorized site makes a request on your behalf using your cookies.

> **NOTE** We often think of hacking in terms of a hacker gaining access to your data. But in the case of CSRF, the hacker can do damage without ever reading your data. Actions with side effects such as adding a tweet or changing a password can have devastating consequences, without ever compromising your data.

Of course, Twitter has taken steps to guard against this issue. Figure C.2 shows an actual request to Twitter to create a new tweet.